



Au cœur de vos attentes. *En réponse à vos besoins*

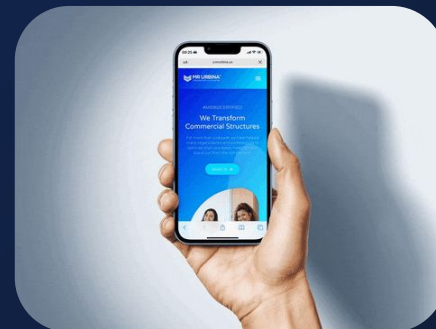
Formation : *ASRS / TISR*

Module 6 : Les attaques sur les applications Web



Table des matières

- 1 : Présentation de l'OWASP
- 2 : OWASP : Top 10 (2017)
- 3 : Manipulation des outils (burpsuite, ZAP Proxy...)
- 4 : Les scanners de vulnérabilités Web





Présentation de l'OWASP



Qu'est ce que l'OWASP ?

- Open Web Application Security Project.
- Une communauté publique et totalement indépendante des fournisseurs et gouvernements.
- Ses principaux objectifs :
 - Fournir des documents et standards dédiés à la sécurité applicative.
 - Produire des outils permettant de mettre en œuvre les mesures préconisées dans les standards notamment pour les tests de sécurité.
- L'accès à tous les outils de l'OWASP est gratuit et ouvert à toute personne
- intéressée par l'amélioration de la sécurité applicative.



OWASP : Top 10



Qu'est ce que l'OWASP ?

2017

A01:2017-Injection

A02:2017-Broken Authentication

A03:2017-Sensitive Data Exposure

A04:2017-XML External Entities (XXE)

A05:2017-Broken Access Control

A06:2017-Security Misconfiguration

A07:2017-Cross-Site Scripting (XSS)

A08:2017-Insecure Deserialization

A09:2017-Using Components with Known Vulnerabilities

A10:2017-Insufficient Logging & Monitoring

2021

A01:2021-Broken Access Control

A02:2021-Cryptographic Failures

A03:2021-Injection

(New) A04:2021-Insecure Design

A05:2021-Security Misconfiguration

A06:2021-Vulnerable and Outdated Components

A07:2021-Identification and Authentication Failures

(New) A08:2021-Software and Data Integrity Failures

A09:2021-Security Logging and Monitoring Failures*

(New) A10:2021-Server-Side Request Forgery (SSRF)*

* From the Survey

A1. Contrôles d'accès défaillants

- de la cinquième position à celle de catégorie présentant le risque de sécurité le plus sérieux pour une application web ; les données partagées indiquent, qu'en moyenne, 3,81% des applications testées avaient une ou plusieurs Common Weakness Enumeration (CWEs) avec plus de 318k occurrences de CWEs de cette catégorie. Les 34 CWEs associées ont eu plus d'occurrences dans les applications auditées que n'importe quelle autre catégorie.

A2. Défaillances cryptographiques

- gagne une position et prend la deuxième place, précédemment connue sous le nom de A3:2017-Exposition de données sensibles, qui était un symptôme large plutôt qu'une cause principale. L'accent est mis sur des défaillances liées à la cryptographie, ce qui était le cas implicitement auparavant. Cette catégorie entraîne souvent une exposition de données sensibles ou une compromission de système.

A3. Injection

- glisse à la troisième position. 94% des applications ont été testées sur des vulnérabilités de ce type, avec une incidence maximale de 19% et une incidence moyenne de 3,37%. Les 33 CWEs associées à cette catégorie ont eu le deuxième plus grand nombre d'occurrences. Cross-Site Scripting fait désormais partie de cette catégorie dans cette édition.

A4. Conception non sécurisée

- Est une nouvelle catégorie, avec un accent sur les défauts de conception. Si nous voulons ajouter des contrôles en amont, nous avons besoin de modèles de menaces, de modèles et principes de conception sécurisés, et d'architectures de référence. Une conception non sécurisée ne peut pas être corrigée par une implémentation parfaite car, par définition, les contrôles de sécurité nécessaires pour se défendre contre certaines attaques n'ont jamais été créés.

A5. Mauvaise configuration de sécurité

- gagne une place ; 90% des applications ont été testées sur des vulnérabilités de ce type, avec une incidence moyenne de 4,5% et plus de 208k occurrences des CWEs associées. Avec des logiciels de plus en plus paramétrables, il n'est pas surprenant de voir cette catégorie prendre de l'ampleur. L'ancienne catégorie **A4:2017-XML Entités externes (XXE)** est incluse dans celle-ci.

A6. Composants vulnérables et obsolètes

- Etait précédemment nommée Utilisation de Composants avec des Vulnérabilités Connues. Elle se place deuxième de l'enquête auprès de la communauté du Top 10, mais pouvait également entrer dans le Top 10 via l'analyse de données. Cette catégorie progresse depuis sa neuvième place en 2017, elle est un problème connu dont nous avons du mal à tester et à mesurer les risques. Il s'agit de la seule catégorie à n'avoir aucunes Common Vulnerability and Exposures (CVEs) associées aux CWEs concernées, en conséquence les coefficients d'impact et de poids ont été renseignés à 5.0 par défaut.

A7. Identification et authentification de mauvaise qualité

- était précédemment Authentification de mauvaise qualité, elle perd la deuxième place. Elle inclut désormais des CWEs également liées aux échecs d'identification. Cette catégorie est toujours présente dans le Top 10, mais la mise à disposition croissante de frameworks standardisés semble aider.

A8. Manque d'intégrité des données et du logiciel

- est une nouvelle catégorie, se concentrant sur la formulation d'hypothèses sur les mises à jour logicielles, les données critiques et les pipelines CI/CD sans vérifier leur intégrité. L'un des impacts les plus élevés à partir des données de Common Vulnerability and Exposures/Common Vulnerability Scoring System (CVE/CVSS) associées aux 10 CWEs de cette catégorie. A8:2017-Désérialisation non sécurisée, listée en 2017, est désormais partie intégrante de cette catégorie.

A9. Carence des systèmes de contrôle et de journalisation

- précédemment A10:2017-Supervision et Journalisation Insuffisantes, est ajoutée de l'enquête auprès de l'industrie (3ème), précédemment à la dixième place. Cette catégorie a été étendue pour inclure plus de types de défaillances, est difficile à tester et est dès lors mal représentée dans les données CVE/CVSS. Toutefois, des incidents dans cette catégorie peuvent impacter directement la visibilité, la levée d'alertes et l'analyse forensique.

A10. Falsification de requête côté serveur

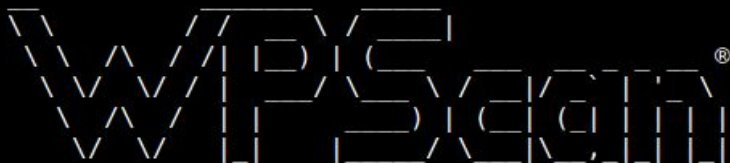
- provient de l'enquête auprès de la communauté Top 10 (1ère). Les données montrent une incidence faible, avec un taux de couverture des tests supérieur à la moyenne, accompagné de notes de potentiel d'exploitabilité et d'impact supérieur à la moyenne. Cette catégorie est un exemple où les membres de la communauté sécurité nous indiquent que cette catégorie est importante, même si cela ne transparaît pas encore dans les données.



Manipulation des outils



```
$ docker run wpscanteam/wpscan --url www.██████████.com
```



WordPress Security Scanner by the WPScan Team
Version 2.9.5-dev

Sponsored by Sucuri - <https://sucuri.net>
@_WPScan_, @ethicalhack3r, @erwan_lr, @_FireFart_

```
[+] URL: http://www.██████████.com/
```

```
[+] Started: Tue Jul 3 15:59:26 2018
```

```
[+] Interesting header: LINK: <http://www.██████████.com/wp-json/>; rel="https://api.w.org/"
```

```
[+] Interesting header: LINK: <http://www.██████████.com/>; rel=shortlink
```

```
[+] Interesting header: SERVER: nginx/1.14.0
```

```
[+] Interesting header: X-POWERED-BY: PHP/7.2.5
```

```
$ python sqlmap.py -u "http://debiandev/sqlmap/mysql/get_int.php?id=1" --batch
```

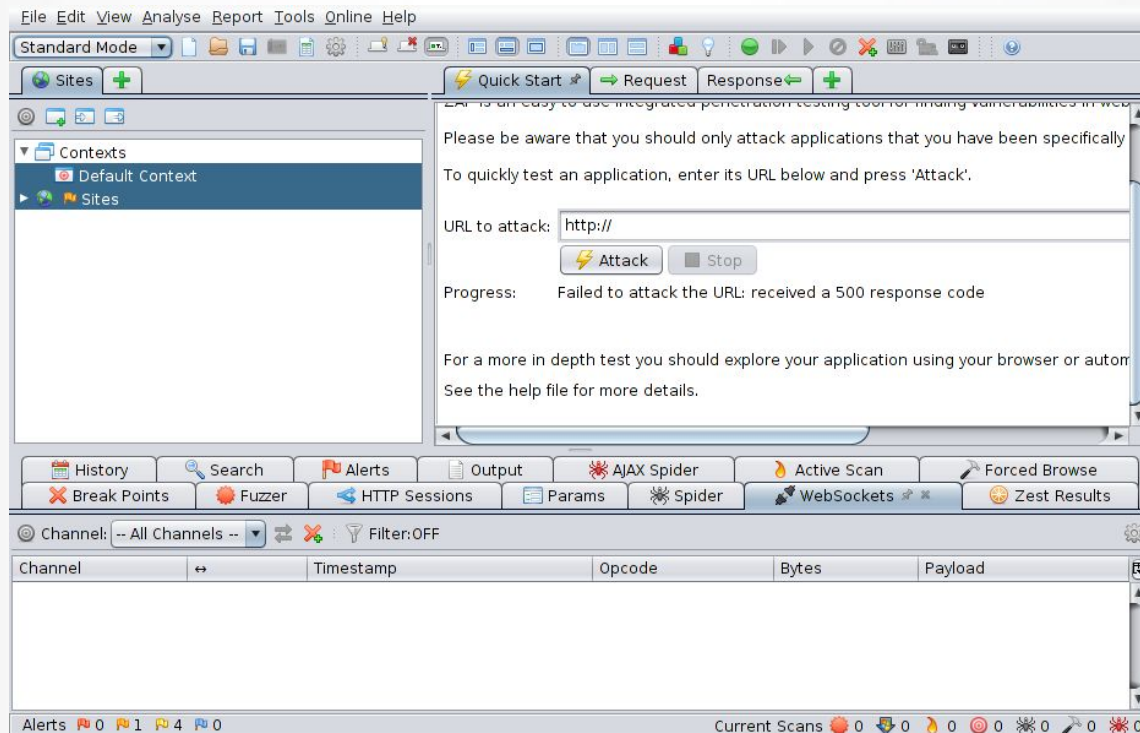


```
[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program
```

```
[*] starting @ 10:44:53 /2019-04-30/
```

```
[10:44:54] [INFO] testing connection to the target URL
[10:44:54] [INFO] heuristics detected web page charset 'ascii'
[10:44:54] [INFO] checking if the target is protected by some kind of WAF/IPS
[10:44:54] [INFO] testing if the target URL content is stable
[10:44:55] [INFO] target URL content is stable
[10:44:55] [INFO] testing if GET parameter 'id' is dynamic
[10:44:55] [INFO] GET parameter 'id' appears to be dynamic
[10:44:55] [INFO] heuristic (basic) test shows that GET parameter 'id' might be injectable
(possible DBMS: 'MySQL')
```

ZAP Proxy



Burp Suite

The screenshot displays the Burp Suite interface with the following sections:

- Tasks:** Shows three tasks: 1. Live passive crawl from Proxy (all traffic), 12. Crawl of (Default configuration), and 17. Audit of (Default configuration). Each task has a progress bar and statistics for requests, errors, and responses.
- Issue activity:** A table listing various security issues found during the scan. The table has columns for #, Task, Time, Action, Issue type, Host, and Path. Issues include Unencrypted communications, Cleartext submission of password, Password submitted using GET method, Strict transport security not enforced, Session token in URL, Cookie without HttpOnly flag set, and SQL Injection.
- Event log:** A table showing a sequence of events, including authentication failures and audit item failures. The table has columns for Time, Type, Source, and Message.
- Advisory:** A detailed view of an SQL Injection issue. It includes a red warning icon, the title "SQL Injection", and a "Compare responses" button. The advisory text describes the issue, its severity (High), confidence (Certain), host (http://www.youcanattackme.com), and path (/vulnerabilities/brute/). It also provides a detailed description of the vulnerability and the specific payload used for the attack.

#	Task	Time	Action	Issue type	Host	Path
1	2	12:09:07 24 Aug 2018	Issue found	Unencrypted communications	http://www.youcanatta...	/
4	2	12:09:28 24 Aug 2018	Issue found	Cleartext submission of password	http://www.youcanatta...	/vulnerability
5	2	12:09:29 24 Aug 2018	Issue found	Cleartext submission of password	http://www.youcanatta...	/vulnerability
6	2	12:09:29 24 Aug 2018	Issue found	Password submitted using GET me...	http://www.youcanatta...	/vulnerability
9	2	12:09:29 24 Aug 2018	Issue found	Cleartext submission of password	http://www.youcanatta...	/vulnerability
11	2	12:09:29 24 Aug 2018	Issue found	Strict transport security not enforced	https://www.google.com	/recaptcha/
12	2	12:09:29 24 Aug 2018	Issue found	Session token in URL	http://www.youcanatta...	/vulnerability
14	2	12:10:05 24 Aug 2018	Issue found	Cookie without HttpOnly flag set	http://www.youcanatta...	/security.ph
15	2	12:10:30 24 Aug 2018	Issue found	Strict transport security not enforced	https://firefox.settings...	/v1/buckets
16	2	12:10:30 24 Aug 2018	Issue found	Strict transport security not enforced	https://firefox.settings...	/v1/buckets
18	2	12:10:30 24 Aug 2018	Issue found	Strict transport security not enforced	https://blocklists.seth...	/v1/blocklist
24	4	12:12:35 24 Aug 2018	Issue found	Cross-site scripting (reflected)	http://www.youcanatta...	/vulnerability
32	2	12:12:53 24 Aug 2018	Issue found	Password submitted using GET me...	http://www.youcanatta...	/vulnerability
38	4	12:14:14 24 Aug 2018	Issue found	SQL Injection	http://www.youcanatta...	/vulnerability
40	4	12:14:14 24 Aug 2018	Issue found	Cross-site scripting (reflected)	http://www.youcanatta...	/vulnerability
42	4	12:14:15 24 Aug 2018	Issue found	Cross-site scripting (reflected)	http://www.youcanatta...	/vulnerability
45	2	12:15:14 24 Aug 2018	Issue found	Cross-site scripting (DOM-based)	http://www.youcanatta...	/vulnerability
50	8	12:17:37 24 Aug 2018	Issue found	Cleartext submission of password	http://www.youcanatta...	/login.php
52	8	12:17:38 24 Aug 2018	Issue found	Session token in URL	http://www.youcanatta...	/vulnerability
116	10	12:24:16 24 Aug 2018	Issue found	Session token in URL	http://www.youcanatta...	/vulnerability
117	10	12:24:16 24 Aug 2018	Issue found	Session token in URL	http://www.youcanatta...	/vulnerability

Time	Type	Source	Message
13:00:47 24 Aug 2018	Error	Proxy	[80] Authentication failure from emprdv1s.service-now.com
13:00:40 24 Aug 2018	Critical	Suite	[73] Could not start embedded browser
12:54:34 24 Aug 2018	Error	Proxy	[2] The client failed to negotiate an SSL connection to emprdv1s
12:38:15 24 Aug 2018	Info	Task 11	Paused due to error: 21 consecutive audit items have failed.
12:38:12 24 Aug 2018	Info	Task 11	Paused due to error: 20 consecutive audit items have failed.
12:38:04 24 Aug 2018	Info	Task 11	Paused due to error: 19 consecutive audit items have failed.
12:38:04 24 Aug 2018	Info	Task 11	Paused due to error: 18 consecutive audit items have failed.
12:37:33 24 Aug 2018	Info	Task 11	Paused due to error: 17 consecutive audit items have failed.
12:37:32 24 Aug 2018	Info	Task 11	Paused due to error: 16 consecutive audit items have failed.
12:37:31 24 Aug 2018	Info	Task 11	Paused due to error: 15 consecutive audit items have failed.
12:37:11 24 Aug 2018	Info	Task 11	Paused due to error: 14 consecutive audit items have failed.
12:37:08 24 Aug 2018	Info	Task 11	Paused due to error: 13 consecutive audit items have failed.
12:37:08 24 Aug 2018	Info	Task 11	Paused due to error: 12 consecutive audit items have failed.
12:36:24 24 Aug 2018	Info	Task 11	Paused due to error: 11 consecutive audit items have failed.

SQL Injection

Issue: **SQL Injection**
Severity: **High**
Confidence: **Certain**
Host: <http://www.youcanattackme.com>
Path: <http://www.youcanattackme.com/vulnerabilities/brute/>

Issue detail

The **username** parameter appears to be vulnerable to SQL injection attacks. A single quote was submitted in the username parameter, and a database error message was returned. Two single quotes were then submitted and the error message disappeared. You should review the contents of the error message, and the application's handling of other input, to confirm whether a vulnerability is present.

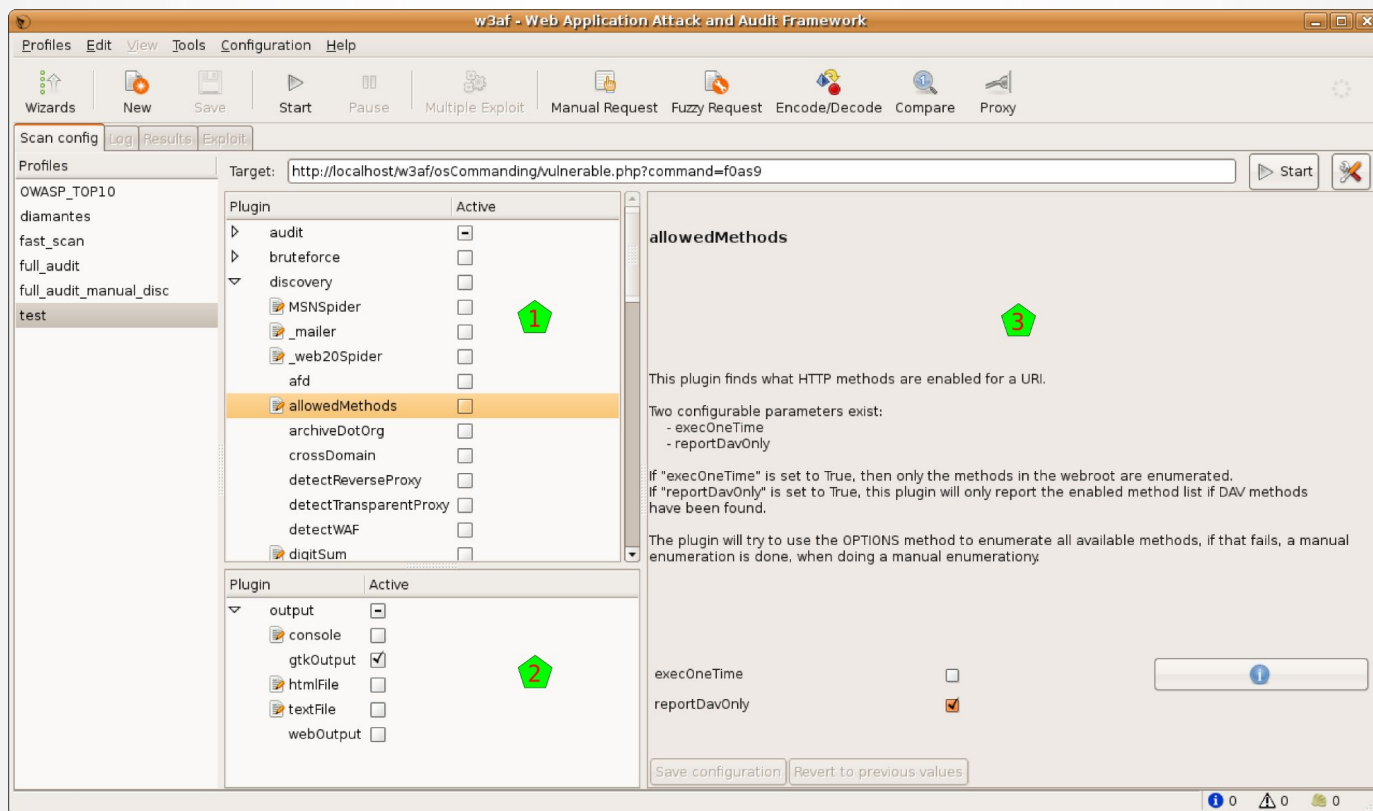
Additionally, the payload `'*select*from(select(sleep(20)))a'*` was submitted in the username parameter. The application took 3001.5 milliseconds to respond to the request, compared with 1.5 milliseconds for the control request. This indicates that the injected payload was successful.



Les scanners de vulnérabilités Web



w3af (open source)



Arachni (open source)

The screenshot displays the Arachni web interface in a Mozilla Firefox browser. The address bar shows the URL `http://testfire.net - Scans - Arachni - Mozilla Firefox`. The browser's address bar also shows `http://localhost:3000/scans/2`. The page title is "Arachni v0.4.6 - WebUI v0.4.3". The interface includes a navigation bar with tabs for "Scans", "Profiles", "Dispatchers", and "Users". The "Scans" tab is active, showing a list of scans. The "Issues" section is selected, displaying a list of 23 issues. A sidebar on the left provides a summary of issues by severity: High (6), Medium (1), Low (2), and Informational (14). The main content area lists the issues, including Path Traversal, Cross-Site Scripting (XSS), SQL Injection, Cross-Site Scripting (XSS) in HTML tag, Unencrypted password form, Directory listing, Password field with auto-complete, Allowed HTTP methods, HttpOnly cookie, Insecure cookie, Interesting response, and HTML object. Each issue entry includes a description, a URL, an input field, and an element type.

Issues [23]

Issues may be missing some context while the scan is running.
You better wait until the scan is over to review them as the meta-analysis phase will flag probable false-positives and other untrusted issues accordingly.

All [23] * Fixed [0] ✓ Verified [0] ⚙ Pending verification [0] ✗ False positives [0] ⚙ Awaiting review [23]

Listing all logged issues.

TOGGLE BY SEVERITY
Reset Show all Hide all

NAVIGATE TO

- High 6
- Medium 1
- Low 2
- Informational 14

URL	Input	Element
Path Traversal 1		
The web application enforces improper limitation of a pathname to a restricted directory. (CWE)		
http://testfire.net/default.aspx?content=security.htm	content	Link
Cross-Site Scripting (XSS) 2		
Client-side code (like JavaScript) can be injected into the web application which is then returned to the user's browser. This can lead to a compromise of the client's system or serve as a pivoting point for other attacks. (CWE)		
http://testfire.net/search.aspx	txtSearch	Form
http://testfire.net/search.aspx?txtSearch=arachni_text	txtSearch	Link
SQL Injection 2		
SQL code can be injected into the web application. (CWE)		
http://testfire.net/bank/login.aspx	passw	Form
http://testfire.net/bank/login.aspx	uid	Form
Cross-Site Scripting (XSS) in HTML tag 1		
Unvalidated user input is being embedded in a HTML element. This can lead to a Cross-Site Scripting vulnerability or a form of HTML manipulation. (CWE)		
http://testfire.net/bank/login.aspx	uid	Form
Unencrypted password form 1		
Transmission of password does not use an encrypted channel. (CWE)		
http://testfire.net/bank/login.aspx	passw	Form
Directory listing 1		
Password field with auto-complete 1		

Acunetix (Payant)

The screenshot displays the Acunetix Web Vulnerability Scanner (Enterprise edition) interface. The main window shows the scan results for 'Scan Thread 1 (http://testphp.acunetix.com:80/)' which is finished with 341 alerts. The left pane shows the 'Tools Explorer' with various tools like Site crawler, HTTP editor, and Reporter. The right pane shows 'Vulnerability information' with a 'Threat level' of 'Level 3: High' and a bar chart showing the distribution of alerts: 252 High, 9 Medium, 25 Low, and 55 Informational. The bottom pane shows the 'Activity window' with a log of the scanning process.

Acunetix Web Vulnerability Scanner (Enterprise edition)

File Tools Help

New scan

Tools Explorer

Web Vulnerability Scanner

Tools

Site crawler

Target finder

HTTP editor

HTTP sniffer

HTTP fuzzer

Authentication tester

Reporter

Compare results

Configuration

Settings

Scanning profiles

General

Program updates

Version information

Licensing

Support Center

How to purchase

Scan results

Scan Thread 1 (http://testphp.acunetix.com:80/)

Status

Finished (341 alerts)

Alerts (341)

Site Structure

/

OK (200)

CVS

_mmServerScripts

admin

OK (200)

AJAX

OK (200)

Flash

OK (200)

images

OK (200)

login

OK (200)

secured

OK (200)

artists.php

OK (200)

cart.php

OK (200)

categories.php

OK (200)

disclaimer.php

OK (200)

favicon.ico

OK (200)

guestbook.php

OK (200)

index.bak

OK (200)

index.BAK

OK (200)

index.php

OK (200)

listproducts.php

OK (200)

login.php

OK (200)

Vulnerability information

Threat level

acunetix threat level

Level 3: High

Acunetix threat level 3

One or more high-severity type vulnerabilities have been discovered by the scanner. A malicious user can exploit these vulnerabilities and compromise the backend database and/or deface your website.

Alerts found

Total alerts found 341

High 252

Medium 9

Low 25

Informational 55

Scan information

Activity window

8 modules loaded.

Crawler tool initialized

Started scanning

Determining necessary updates.

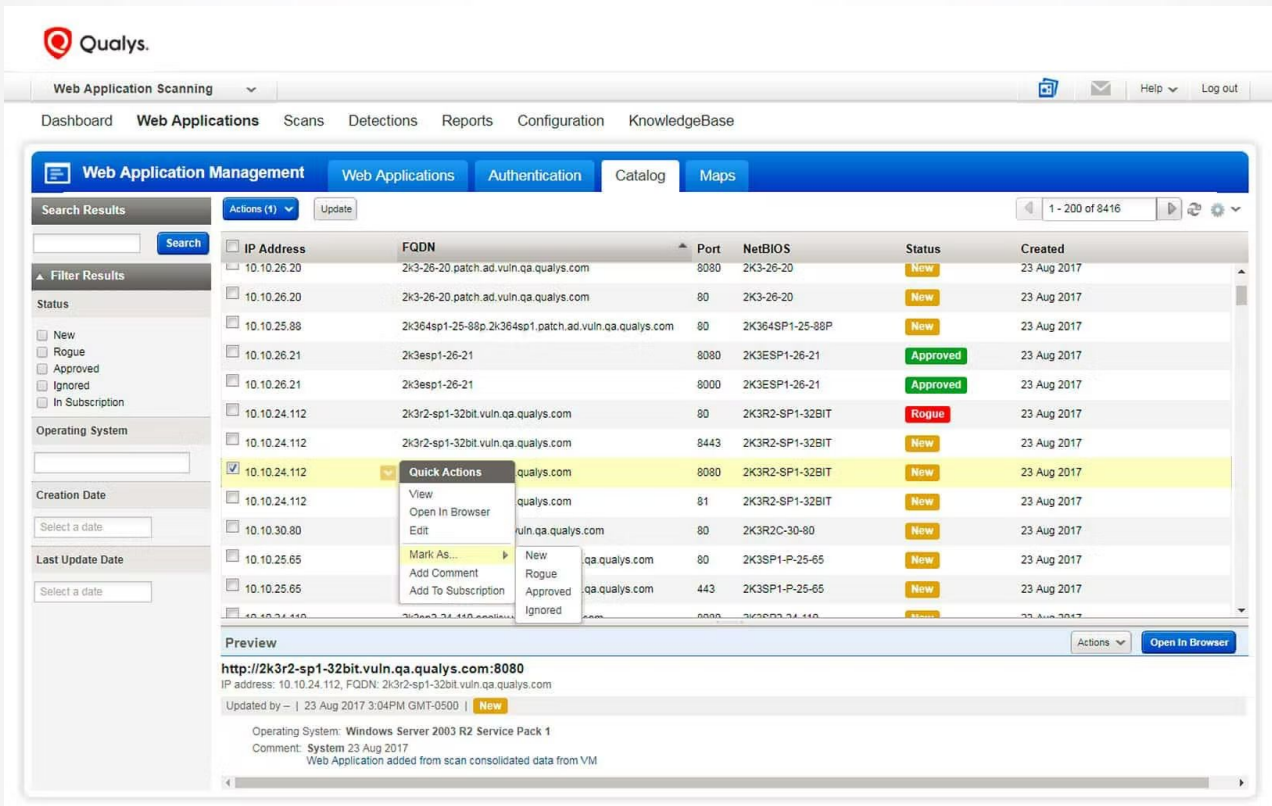
No updates needed.

Finished scanning.

Application Log Error Log Search Results

Ready

Qualys (payant)



The screenshot displays the Qualys Web Application Management interface. The top navigation bar includes the Qualys logo, a dropdown menu for "Web Application Scanning", and links for "Dashboard", "Web Applications", "Scans", "Detections", "Reports", "Configuration", and "KnowledgeBase". The main content area is titled "Web Application Management" and features a search bar, a "Search" button, and a "Filter Results" section. The "Filter Results" section includes checkboxes for "Status" (New, Rogue, Approved, Ignored, In Subscription) and "Operating System". Below the filters, there are input fields for "Creation Date" and "Last Update Date". The main table lists web applications with columns for "IP Address", "FQDN", "Port", "NetBIOS", "Status", and "Created". A "Quick Actions" menu is visible over the table, offering options like "View", "Open In Browser", "Edit", "Mark As...", "Add Comment", and "Add To Subscription". The "Preview" section at the bottom shows details for a specific web application, including its IP address, FQDN, and operating system.

Qualys.

Web Application Scanning

Dashboard Web Applications Scans Detections Reports Configuration KnowledgeBase

Web Application Management Web Applications Authentication Catalog Maps

Search Results

Search

Filter Results

Status

☐ New
☐ Rogue
☐ Approved
☐ Ignored
☐ In Subscription

Operating System

Creation Date

Select a date

Last Update Date

Select a date

Actions (1) Update

1 - 200 of 8416

IP Address	FQDN	Port	NetBIOS	Status	Created
☐ 10.10.26.20	2k3-26-20.patch.ad.vuln.qa.qualys.com	8080	2K3-26-20	New	23 Aug 2017
☐ 10.10.26.20	2k3-26-20.patch.ad.vuln.qa.qualys.com	80	2K3-26-20	New	23 Aug 2017
☐ 10.10.25.88	2k364sp1-25-88p.2k364sp1.patch.ad.vuln.qa.qualys.com	80	2K364SP1-25-88P	New	23 Aug 2017
☐ 10.10.26.21	2k3esp1-26-21	8080	2K3ESP1-26-21	Approved	23 Aug 2017
☐ 10.10.26.21	2k3esp1-26-21	8000	2K3ESP1-26-21	Approved	23 Aug 2017
☐ 10.10.24.112	2k3r2-sp1-32bit.vuln.qa.qualys.com	80	2K3R2-SP1-32BIT	Rogue	23 Aug 2017
☐ 10.10.24.112	2k3r2-sp1-32bit.vuln.qa.qualys.com	8443	2K3R2-SP1-32BIT	New	23 Aug 2017
☒ 10.10.24.112	2k3r2-sp1-32bit.vuln.qa.qualys.com	8080	2K3R2-SP1-32BIT	New	23 Aug 2017
☐ 10.10.24.112	2k3r2-sp1-32bit.vuln.qa.qualys.com	81	2K3R2-SP1-32BIT	New	23 Aug 2017
☐ 10.10.30.80	2k3r2c-30-80	80	2K3R2C-30-80	New	23 Aug 2017
☐ 10.10.25.65	2k3sp1-p-25-65	80	2K3SP1-P-25-65	New	23 Aug 2017
☐ 10.10.25.65	2k3sp1-p-25-65	443	2K3SP1-P-25-65	New	23 Aug 2017

Quick Actions

- View
- Open In Browser
- Edit
- Mark As...
- Add Comment
- Add To Subscription

New
Rogue
Approved
Ignored

Preview

Actions Open In Browser

http://2k3r2-sp1-32bit.vuln.qa.qualys.com:8080

IP address: 10.10.24.112, FQDN: 2k3r2-sp1-32bit.vuln.qa.qualys.com

Updated by - | 23 Aug 2017 3:04PM GMT-0500 | New

Operating System: Windows Server 2003 R2 Service Pack 1

Comment: System 23 Aug 2017

Web Application added from scan consolidated data from VM

A yellow L-shaped graphic element consisting of a horizontal line at the top and a vertical line on the right, forming an open square frame.

Fin du Module 6
IPREC